SYSTEM CLASSIFICATION POLICY

POL-005 | Issued under the Information Management Framework

Document ID: POL-005
Version: 1.0 — DRAFT
Parent Framework: IMF-001 Information Management Framework
Classification: Internal Use
Owner: Chief Information Officer
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	System Classification Policy
Document ID	POL-005
Version	1.0 — DRAFT
Status	Draft for Review
Parent Framework	IMF-001 — Information Management Framework
Related Policy	POL-001 — Data Classification Policy
Document Owner	Chief Information Officer
Custodian	Information Security / IT Governance
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]
Regulatory Alignment	ISO/IEC 27001:2022, NIST CSF, GxP, 21 CFR Part 11, EU Annex 11, SOX

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose

This Policy establishes mandatory requirements for the classification of all information systems at [Company Name] according to their criticality. It operationalises the System Criticality axis of the classification schema defined in the Information Management Framework (IMF-001) and works in tandem with the Data Classification Policy (POL-001).

System criticality classification is the mechanism by which [Company Name] determines the appropriate level of availability, resilience, recovery, and operational controls for each system. It ensures that investment in system protection is proportionate to the business and regulatory risk associated with any given system's unavailability or failure.

This Policy establishes a foundational principle that distinguishes it from data classification: a system's criticality is not solely determined by the sensitivity or criticality of the data it holds. It must also reflect the system's functional importance — the operational impact of its unavailability, independent of its data.

2. Scope

This Policy applies to:

- All information systems, applications, platforms, and infrastructure components owned, operated, or contracted by [Company Name]
- All deployment models: on-premises, cloud-hosted (IaaS, PaaS, SaaS), hybrid, and third-party managed
- All system types including, but not limited to: business applications, clinical systems, manufacturing execution systems, ERP, CRM, identity and access management systems, network infrastructure, and development environments
- All personnel responsible for the ownership, management, or operation of information systems

Third-party systems that process [Company Name] data or integrate with [Company Name] systems must be classified in accordance with this Policy. The System Owner retains accountability for classification even where a system is managed externally.

3. Policy Statement

All information systems at [Company Name] must be classified according to their criticality tier as defined in this Policy. Classification must be:

- Completed for every system at the point of procurement, development, or onboarding
- Performed using the dual-input assessment process defined in Section 5
- Documented in the Corporate Asset Register and maintained current
- Reviewed at least annually by the System Owner and confirmed in writing
- Revisited immediately if there is a material change in the system's function, data holdings, integrations, or regulatory status

No system may be deployed into a production environment without a completed and approved criticality classification.

4. System Criticality Tiers

System criticality is classified into four tiers based on the operational and regulatory impact of system unavailability or failure. These tiers drive the recovery objectives and architectural requirements defined in Section 6.

Tier 1 — Extremely Critical

Attribute	Detail
Definition	System failure causes immediate, company-wide operational outage, regulatory breach, or patient/product safety risk. No viable workaround exists.
Impact Horizon	Immediate (minutes to hours).
Examples	Active Directory / Identity Provider, DNS infrastructure, core network routing, GxP manufacturing execution systems, electronic batch record systems, ERP (financial close), clinical trial data management systems.
RPO	Less than 1 hour
RTO	Less than 4 hours
Architecture Requirement	High availability (HA) active-active or active-passive configuration. Geographically redundant. Automated failover. Disaster recovery environment maintained in warm standby.
Monitoring	24/7 automated monitoring with immediate alerting. Incident response SLA: 15 minutes.
System Assurance (POL-006)	GxP-flagged: Track A — Full CSV/CSA per POL-006. Non-GxP Tier 1 systems: Track C — Structured Qualification (URS, test plan, execution evidence, formal sign-off).

Tier 2 — Critical

Attribute	Detail
Definition	System failure significantly degrades business operations within hours. A limited workaround may exist but is unsustainable beyond a short period.
Impact Horizon	Hours (typically 2–8 hours before material impact).
Examples	CRM, LIMS (non-GxP), document management systems, HR systems, financial reporting (non-period-close), email and collaboration platforms, SOX-in-scope systems.
RPO	Less than 4 hours
RTO	Less than 24 hours
Architecture Requirement	High availability recommended. Disaster recovery environment in cold or warm standby. Automated backups with tested restore capability.
Monitoring	Business hours monitoring with after-hours on-call escalation. Incident response SLA: 1 hour.
System Assurance (POL-006)	GxP-flagged: Track A — Full CSV/CSA per POL-006. SOX-flagged (non-GxP): Track B — ITGC evidence package. Non-regulated: Track C — Structured Qualification per POL-006.

Tier 3 — Standard

Attribute	Detail
Definition	System failure affects specific functions or teams but does not impair core business operations. A practical workaround is available for the duration of an outage.
Impact Horizon	Days. Impact grows if outage extends beyond 72 hours.
Examples	Internal wikis, non-critical reporting tools, development and test environments, internal project management tools, non-integrated departmental applications.
RPO	Less than 24 hours
RTO	Less than 72 hours
Architecture Requirement	Standard backup with documented restore procedure. Single-instance deployment acceptable. No HA requirement.
Monitoring	Business hours monitoring. Incident response SLA: 4 hours (business hours).
System Assurance (POL-006)	Track D — Lightweight Testing Assurance per POL-006 (acceptance testing + deployment approval). Note: introduction of GxP data requires immediate reclassification to minimum Tier 2 and Track A assurance.

Tier 4 — None / Low Impact

Attribute	Detail
Definition	System failure has negligible operational impact. The system can remain offline for extended periods without material business consequence.
Impact Horizon	Weeks or longer.
Examples	Legacy archival systems with no active use, sandbox environments, informal team tools not connected to production systems.
RPO	Best effort
RTO	Best effort
Architecture Requirement	No specific availability requirement. Standard backup recommended but not mandated.
Monitoring	No mandatory monitoring. Manual checks acceptable.
System Assurance (POL-006)	Track D — Lightweight Testing Assurance per POL-006. GxP data introduction requires immediate reclassification and Track A validation.

5. Dual-Input Classification Assessment

A system's final criticality classification is derived from two independent inputs that must each be assessed separately. The higher result of the two inputs determines the final classification. This approach ensures that systems with low data criticality but high functional importance — such as DNS or network infrastructure — are not underclassified.

5.1 Input A — Data-Derived Criticality

Data-Derived Criticality reflects the operational impact of the data the system holds or processes becoming unavailable or corrupted. It is assessed by answering the following question:

"What is the business impact if the data held in this system becomes unavailable or is lost?"

Data Criticality Assessment	Resulting Tier
Loss of data would cause immediate, company-wide operational failure, regulatory breach, or patient/product safety risk.	Tier 1 — Extremely Critical
Loss of data would significantly impair operations within hours and could not be easily reconstructed.	Tier 2 — Critical
Loss of data would impair specific functions but could be reconstructed or worked around within days.	Tier 3 — Standard
Loss of data would have negligible operational impact. Data is easily reconstructed or is of low business value.	Tier 4 — None

5.2 Input B — Functional Criticality

Functional Criticality reflects the operational impact of the system itself becoming unavailable, regardless of the data it holds. It is assessed by answering the following question:

"What is the operational impact if this system is unavailable, regardless of what data it holds?"

Functional Criticality Assessment	Resulting Tier
System unavailability causes immediate, company-wide operational failure or safety risk. No workaround exists. (Example: DNS, Active Directory, core network.)	Tier 1 — Extremely Critical

Functional Criticality Assessment	Resulting Tier
System unavailability significantly degrades operations within hours. Limited workaround is available but not sustainable. (Example: ERP during month-end close, email platform.)	Tier 2 — Critical
System unavailability affects a specific function or team. A practical workaround exists for the duration of an outage.	Tier 3 — Standard
System unavailability has negligible operational impact. Business continues normally.	Tier 4 — None

5.3 Final Classification Rule

The system's final criticality classification is the higher of Input A and Input B.

Example	Input A (Data)	Input B (Functional)	Final Classification
DNS infrastructure	Tier 4 — None	Tier 1 — Extremely Critical	Tier 1 — Extremely Critical
Clinical trial CDMS	Tier 1 — Extremely Critical	Tier 2 — Critical	Tier 1 — Extremely Critical
Internal wiki	Tier 4 — None	Tier 3 — Standard	Tier 3 — Standard
ERP (financial close)	Tier 2 — Critical	Tier 1 — Extremely Critical	Tier 1 — Extremely Critical
Archival document store	Tier 3 — Standard	Tier 4 — None	Tier 3 — Standard

6. Controls Derived from Classification

The following table summarises the minimum controls mandated for each criticality tier. Detailed requirements are specified in the relevant subordinate Policies and SOPs.

Control Domain	Tier 1 — Extremely Critical	Tier 2 — Critical	Tier 3 — Standard	Tier 4 — None
RPO	< 1 hour	< 4 hours	< 24 hours	Best effort

Control Domain	Tier 1 — Extremely Critical	Tier 2 — Critical	Tier 3 — Standard	Tier 4 — None
RTO	< 4 hours	< 24 hours	< 72 hours	Best effort
Architecture	HA active-active or active-passive. Geo-redundant. Automated failover.	HA recommended. DR warm/cold standby.	Single-instance. Standard backup.	No requirement.
Backup Frequency	Continuous or near-continuous replication	Minimum 4-hourly	Daily	Weekly or manual
DR Testing	Full DR failover test: annually minimum. Tabletop: semi-annually.	DR test: annually. Tabletop: annually.	Restore test: annually.	Not required.
Monitoring	24/7 automated. 15-min incident SLA.	Business hours + on-call. 1-hr SLA.	Business hours. 4-hr SLA.	No requirement.
Change Management	Normal Change — CAB approval required per POL-007. Validation impact assessment mandatory for all changes to GxP-flagged systems (no Minor Change category applies).	Normal Change — CAB approval required per POL-007. Validation impact assessment required for GxP-flagged systems.	Minor Change — System Owner approval per POL-007. No CAB review required.	Minor Change — System Owner approval per POL-007.
Patch Management	Emergency patches: 24 hours. Critical: 7 days. High: 30 days.	Critical: 14 days. High: 30 days.	Critical: 30 days. High: 90 days.	Best effort.
Access Review	Quarterly	Semi-annual	Annual	Annual
System Assurance (POL-006)	GxP-flagged: Track A — Full CSV/CSA required. Non-GxP: Track C — Structured Qualification (URS, test plan,	GxP-flagged: Track A — Full CSV/CSA required. SOX-flagged (non-GxP): Track B — ITGC evidence package. Non-	No regulatory flag: Track D — Lightweight Testing Assurance (acceptance testing + deployment	Track D — Lightweight Testing Assurance. GxP data introduction triggers immediate Tier 2 reclassification.

Control Domain	Tier 1 — Extremely Critical	Tier 2 — Critical	Tier 3 — Standard	Tier 4 — None
	execution evidence, formal sign-off).	regulated: Track C — Structured Qualification.	approval). Note: GxP flag triggers minimum Tier 2 reclassification, removing system from Tier 3.	

7. GxP and Regulatory Considerations

Life-sciences regulatory requirements impose additional obligations on systems that process regulated data. The following rules apply alongside the standard criticality classification:

7.1 GxP-Regulated Systems

Any system that creates, modifies, maintains, archives, retrieves, or transmits electronic records that are required by applicable GxP regulation (21 CFR Part 11, EU Annex 11, GMP, GLP, GCP) is designated a GxP-Regulated System. All such systems must:

- Be subject to full Computer System Validation (CSV) or, where permitted, Computer Software Assurance (CSA) per POL-006
- Maintain an immutable, time-stamped audit trail of all data creation, modification, and deletion events
- Enforce electronic signature controls where electronic records are used in lieu of handwritten signatures
- Be classified at a minimum of Tier 2 — Critical, regardless of other inputs
- Have a validated backup and restore process with documented evidence

GxP-Regulated Systems that also meet Tier 1 functional criticality criteria must be classified as Tier 1 — Extremely Critical.

7.2 SOX In-Scope Systems

Systems that form part of the IT General Controls (ITGC) environment for SOX purposes must:

- Be classified at a minimum of Tier 2 — Critical
- Undergo annual ITGC testing covering access management, change management, and backup and recovery controls
- Be flagged as SOX In-Scope in the Corporate Asset Register

7.3 Regulatory Flag in Asset Register

The following regulatory flags must be recorded in the Corporate Asset Register for each system, in addition to its criticality tier:

Flag	Trigger Condition
GxP-Regulated	System creates, modifies, maintains, archives, retrieves, or transmits GxP electronic records.
21 CFR Part 11 / Annex 11	System uses electronic records or electronic signatures in place of paper records under FDA or EMA jurisdiction.
SOX In-Scope	System is within the ITGC boundary for SOX financial reporting controls.

Flag	Trigger Condition
HIPAA	System processes US Protected Health Information (PHI).
GDPR / Privacy-Regulated	System processes EU or other regulated personal data.

8. Roles and Responsibilities

Role	Responsibility
System Owner	Accountable for the classification of their system(s). Completes the dual-input assessment, signs off the classification, and ensures it is maintained current. Responsible for ensuring system controls meet the requirements of the assigned tier.
IT / Infrastructure	Implements the technical controls (architecture, backup, monitoring, patching) mandated by the assigned criticality tier. Advises System Owners on functional criticality assessment.
Information Security	Validates classifications, maintains the Classification Standard, and coordinates the annual review cycle. Adjudicates disputes between System Owners.
Compliance / QA	Reviews GxP and regulatory flag assignments. Oversees CSV/CSA requirements and SOX ITGC scope.
Business Continuity	Sets DR testing schedules and validates that RPO/RTO targets are achievable for Tier 1 and Tier 2 systems.
CIO	Final escalation point for classification disputes. Approves exceptions to this Policy.

9. Classification Process

Full process detail is defined in SOP-005 (System Classification Process) and WI-005 (System Classification Questionnaire). In summary:

Step	Action	Responsible
1	Initiation — any new system procurement, development, or onboarding triggers a mandatory classification assessment.	IT / Project Lead
2	Data-Derived Assessment (Input A) — System Owner completes the data criticality assessment using WI-005,	System Owner

Step	Action	Responsible
	referencing the data classification already assigned under POL-001.	
3	Functional Assessment (Input B) — System Owner and IT jointly complete the functional criticality assessment using WI-005, considering dependencies, integration footprint, and operational impact.	System Owner + IT
4	Final Classification — the higher of Input A and Input B is recorded as the system's criticality tier. Regulatory flags are assigned.	System Owner
5	Approval — classification is reviewed and approved by Information Security. Tier 1 classifications additionally require CISO sign-off.	Information Security / CISO
6	Registration — the approved classification, regulatory flags, RPO/RTO, System Owner, and review date are recorded in the Corporate Asset Register.	IT / System Owner
7	Controls Implementation — IT implements or confirms the technical controls required for the assigned tier per Section 6.	IT
8	Annual Review — classification is reviewed and reconfirmed each year, or sooner if a material change occurs.	System Owner + Information Security

10. Reclassification

A system must be reclassified when any of the following occur:

- The system begins to process data of a different sensitivity or criticality to that originally assessed
- The system's functional role changes materially (e.g., it becomes a critical dependency for another Tier 1 system)
- A new regulatory obligation arises (e.g., the system is brought into GxP or SOX scope)
- A major architectural change alters the system's availability characteristics

Reclassification upward may be initiated by the System Owner or Information Security at any time. Reclassification downward requires approval from the CISO and must be documented in the Asset Register with rationale.

11. Third-Party and Cloud-Hosted Systems

Third-party managed and cloud-hosted systems are subject to this Policy in the same manner as internally hosted systems. The following additional requirements apply:

- The contractual RPO and RTO commitments of the third-party provider must meet or exceed the targets mandated for the system's criticality tier
- The System Owner must obtain and review the provider's Business Continuity and Disaster Recovery documentation prior to onboarding and annually thereafter
- Tier 1 and Tier 2 systems hosted by third parties must be covered under the Third Party and Vendor Risk Policy (POL-013)
- GxP-Regulated systems hosted by third parties must be covered by a Technical Agreement specifying CSV/CSA and audit trail obligations
- The right to audit must be contractually preserved for all Tier 1 and GxP-Regulated third-party systems

12. Policy Exceptions

Exceptions to the requirements of this Policy may only be granted by the CIO in writing, with Information Security endorsement. All exceptions must:

- Document the requirement being excepted and the business or technical justification
- Define compensating controls that mitigate the associated risk
- Specify an expiry date not exceeding 12 months
- Be recorded in the Information Risk Register
- Be reviewed before expiry; if still required, a new exception must be sought

No exception may result in a system being operated with controls below those required by applicable regulation, regardless of internal classification.

13. Related Documents

Document ID	Title	Relationship
IMF-001	Information Management Framework	Parent framework — defines classification schema
POL-001	Data Classification Policy	Data sensitivity classification; Input A to this Policy

Document ID	Title	Relationship
POL-006	Computer System Validation and Qualification Policy	Defines the four assurance tracks (A–D) driven by system classification and regulatory flags from this Policy. GxP flag → Track A; SOX flag (non-GxP) → Track B; Tier 1/2 non-regulated → Track C; Tier 3/4 non-regulated → Track D
POL-007	Change Management Policy	Governs change type eligibility and approval authority by criticality tier and regulatory flags. GxP-flagged systems: validation impact assessment mandatory for all changes; no Minor Change category. Tier 3/4 non-regulated: Minor Change — System Owner approval only
POL-008	Access Control Policy	Governs IAM controls including access review frequency by tier
POL-011	Business Continuity Policy	Governs DR strategy and testing requirements by tier
POL-013	Third Party and Vendor Risk Policy	Governs third-party system classification obligations
SOP-005	System Classification Process	Operationalises this Policy
EXC-001	Exception Management Policy and Register	System criticality tier exceptions affect downstream RTO/RPO, access control, audit trail, and validation requirements across the IMF suite — governed by EXC-001 with ISSG notification required given the cascading effect on other policies
WI-005	System Classification Questionnaire	Dual-input assessment tool

14. Definitions

Term	Definition
Asset Register	The central inventory of all information systems and data assets, including their classification, ownership, and regulatory flags.
CSA	Computer Software Assurance — the FDA's modernised, risk-based approach to assuring software used in regulated activities.
CSV	Computer System Validation — the documented process of demonstrating that a computerised system does what it purports to do in a consistent and reproducible manner.
Data-Derived Criticality	System criticality assessed on the basis of the operational impact of the data the system holds becoming unavailable or corrupted.

Term	Definition
Functional Criticality	System criticality assessed on the basis of the operational impact of the system itself becoming unavailable, independent of its data holdings.
GxP	The collective term for Good Practice regulations in life sciences (GMP, GLP, GCP, GDP, etc.).
HA	High Availability — system architecture designed to ensure a high level of operational continuity, typically through redundancy and failover capability.
ITGC	IT General Controls — the policies and procedures that apply to all systems and support the effectiveness of application controls for SOX purposes.
RPO	Recovery Point Objective — the maximum acceptable age of data at the point of recovery following a system failure.
RTO	Recovery Time Objective — the maximum acceptable duration of a system outage before recovery must be complete.
System Owner	The individual accountable for the lifecycle, classification, and controls applied to a specific information system.

— End of Document —

POL-005 v1.0 DRAFT | [Company Name] | CONFIDENTIAL